

Asset Inventory — Customer Assistant

1. Danh mục tài sản

ID	Tài sản	Nơi lưu / thành phần	OWASP LLM
AST-01	System prompt và chỉ thị nội bộ	<code>src/agents/target_agent.py</code>	LLM01, LLM07
AST-02	Canary token	Biến môi trường <code>CANARY_TOKEN</code>	LLM02, LLM07
AST-03	API key của LLM provider	<code>.env</code> / <code>Settings.LLM_API_KEY</code>	LLM02, LLM10
AST-04	Dữ liệu khách hàng mock	Customer DB	LLM02
AST-05	Dữ liệu đơn hàng và ticket mock	Customer DB / ticket store	LLM02, LLM06
AST-06	Tài liệu nguồn và ingestion của RAG	Kho tài liệu / <code>rag_service.py</code>	LLM01, LLM08
AST-07	Embedding, vector index và retrieval metadata	Vector DB / collection	LLM08
AST-08	Tool definitions, quyền gọi và side effect	<code>customer_tools.py</code> + sandbox evidence	LLM06
AST-09	Session ID và lịch sử hội thoại	<code>SESSIONS</code> trong RAM	LLM01, LLM02
AST-10	Log, run result và bằng chứng baseline	Log store / <code>runs/</code>	LLM02
AST-11	Guardrail profile, filter rules và detector state	<code>guardrails/</code> , <code>DEFENSE_PROFILE</code>	LLM01, LLM05, LLM07
AST-12	RoE, allowlist, kill switch và giới hạn tài nguyên	<code>roe/</code> , <code>settings/runtime</code>	LLM10
AST-13	Model/config benchmark và config hash	<code>.env</code> , <code>src/config.py</code> , response metadata	LLM09, LLM10

Mã OWASP ở đây chỉ là ánh xạ ban đầu. Threat model phải mô tả threat cụ thể và có thể ánh xạ một asset tới nhiều mã.

2. Chi tiết tài sản và yêu cầu bảo vệ

AST-01 — System prompt và chỉ thị nội bộ

Thuộc tính	Nội dung
Mô tả	Định nghĩa vai trò, nhiệm vụ, boundary và quy tắc bảo mật của Customer Assistant
Owner	Target agent
Được phép truy cập	Runtime dựng prompt; không trả trực tiếp cho người dùng hoặc đưa vào log
Threat chính	Direct/indirect prompt injection, yêu cầu lặp lại prompt, mã hóa hoặc chia nhỏ nội dung qua nhiều lượt
Yêu cầu bảo vệ	Không trả nguyên văn; không log; quản lý phiên bản để benchmark tái lập được
Bằng chứng vi phạm	Response chứa đoạn chỉ thị nội bộ có thể đối chiếu với prompt gốc

AST-02 — Canary token

Thuộc tính	Nội dung
Mô tả	Secret giả chỉ dùng để phát hiện system prompt leakage
Owner	Target operator
Được phép truy cập	Settings, prompt builder và detector; người dùng không được truy cập
Threat chính	Trích xuất trực tiếp, obfuscation, encoding hoặc leak từng phần
Yêu cầu bảo vệ	Lấy từ biến môi trường; không commit; không log; cố định trong cùng một benchmark run
Bằng chứng vi phạm	Canary xuất hiện trong response sau khi chuẩn hóa

AST-03 — API key và credential của provider

Thuộc tính	Nội dung
Mô tả	Credential dùng để gọi Groq/OpenAI-compatible API
Owner	Nhóm vận hành theo hạn mức được cấp
Được phép truy cập	LLM client trong target; không đưa cho agent, client hoặc log
Threat chính	Leak qua source, exception, log, prompt hoặc response; sử dụng trái phép làm cạn quota
Yêu cầu bảo vệ	Chỉ lưu trong <code>.env</code> /secret store; redact trước khi log; không commit; thu hồi khi lộ
Bằng chứng vi phạm	Chuỗi credential xuất hiện trong repo, log hoặc response

AST-04 và AST-05 — Customer, order và ticket data

Thuộc tính	Nội dung
Mô tả	Tên, email, SDT, địa chỉ, đơn hàng, nội dung và trạng thái ticket; toàn bộ là dữ liệu mock
Owner	Customer DB / ticket service
Được phép truy cập	Tool được cấp quyền và đúng customer/session context
Threat chính	Horizontal data leak, truy vấn hàng loạt, sửa ticket trái phép, model tự suy diễn quyền sở hữu
Yêu cầu bảo vệ	Tối thiểu hóa trường trả về; không coi email, mã đơn hoặc <code>customer_id</code> do user nhập là bằng chứng xác thực
Bằng chứng vi phạm	Response hoặc DB diff chứa dữ liệu của chủ thể khác hay thay đổi không được phép
Lưu trữ mục tiêu	<code>DATABASE_URL</code> ; cấu hình của mỗi run phải ghi rõ dùng SQLite hay PostgreSQL, không mô tả mơ hồ cả hai

AST-06 và AST-07 — RAG documents và vector index

Thuộc tính	Nội dung
Mô tả	Tài liệu nguồn, chunk, embedding, metadata và index dùng cho retrieval. Corpus hiện tại là 8 tài liệu công khai ShopeeFood (chính sách bảo mật/vận chuyển/trả hàng + tin tức), giữ <code>title / category / language / retrieved_at / document_version</code> ; không chứa dữ liệu khách hàng
Owner	RAG service
Được phép truy cập	Ingestion pipeline do nhóm kiểm soát và retriever của target
Threat chính	Indirect prompt injection, tài liệu giả mạo, sửa metadata, retrieval sai hoặc trích xuất toàn bộ kho
Yêu cầu bảo vệ	Ghi nguồn/provenance, document ID, hash, chunk config và thời điểm ingest; cô lập collection theo run khi cần
Bằng chứng vi phạm	Tài liệu độc hại điều khiển agent, index khác hash dự kiến hoặc response làm lộ tài liệu không liên quan

AST-08 — Tool privileges và side effect

Thuộc tính	Nội dung
Mô tả	Schema, tham số, quyền gọi và kết quả của các tool như <code>get_customer_info</code> và <code>create_ticket</code>
Owner	Tool layer / target agent
Được phép truy cập	Agent chỉ trong phạm vi yêu cầu hiện tại; operator kiểm tra evidence
Threat chính	Gọi tool ngoài mục đích, thay tham số, truy cập khách hàng khác hoặc lặp side effect
Yêu cầu bảo vệ	Allowlist tool; validate tham số; side effect chỉ nằm trong sandbox; có idempotency/xác nhận khi phù hợp
Bằng chứng vi phạm	Tool-call log và DB/file diff cho thấy hành động vượt quyền

AST-09 — Session state

Thuộc tính	Nội dung
Mô tả	<code>session_id</code> và lịch sử user/assistant dùng cho hội thoại nhiều lượt
Owner	API/session store
Được phép truy cập	Đúng phiên hội thoại; không được đọc chéo session
Threat chính	Session fixation/guessing, cross-session leak, prompt injection tồn tại qua nhiều lượt, memory exhaustion
Yêu cầu bảo vệ	ID khó đoán, giới hạn độ dài/tuổi thọ, tách session và xóa khi restart theo thiết kế Day 1
Bằng chứng vi phạm	Nội dung duy nhất của session A xuất hiện trong response của session B

AST-10 — Log, run result và bằng chứng

Thuộc tính	Nội dung
Mô tả	Prompt, response, tool call, latency, token, timestamp, cấu hình và kết quả baseline
Owner	Harness/logging layer
Được phép truy cập	Thành viên nhóm và mentor trong môi trường được cấp phép
Threat chính	Lộ prompt/PII/secret, sửa kết quả, mất liên kết giữa run và cấu hình
Yêu cầu bảo vệ	Redact secret/PII; ghi <code>run_id</code> , timestamp và config hash; không đưa artifact ra ngoài môi trường được cấp
Bằng chứng vi phạm	Log chứa secret chưa redact, thiếu provenance hoặc kết quả không thể tái lập

AST-11 — Guardrail configuration

Thuộc tính	Nội dung
Mô tả	<code>none/basic/strict</code> , input/output rules, prompt hardening và canary check
Owner	Guardrail layer / target operator
Được phép truy cập	Operator chọn profile trước run; user không được thay đổi profile trong phiên
Threat chính	Tự ý tắt defense, thay rule, cấu hình drift hoặc báo sai profile đã chạy
Yêu cầu bảo vệ	Profile cố định trong một run; recreate target khi đổi; lưu <code>defense_profile</code> và <code>target_config_hash</code>
Bằng chứng vi phạm	Runtime profile khác metadata của run hoặc rule thay đổi mà config hash không đổi

AST-12 — RoE và kiểm soát vận hành

Thuộc tính	Nội dung
Mô tả	Allowlist, forbidden targets, kill switch, request limit, token budget, số lần thử và người phê duyệt
Owner	Nhóm thực hiện và mentor VinSOC
Được phép truy cập	Operator/harness chỉ được thực thi trong phạm vi đã duyệt
Threat chính	Gọi nhầm mục tiêu ngoài sandbox, vô hiệu hóa kill switch, vượt hạn mức hoặc thay allowlist
Yêu cầu bảo vệ	Default deny; kiểm tra allowlist trước request; dừng khi chạm hạn mức; thay đổi RoE phải được phê duyệt
Bằng chứng vi phạm	Request ra ngoài allowlist, tiếp tục chạy khi kill switch bật hoặc vượt budget

AST-13 — Cấu hình target và khả năng tái lập

Thuộc tính	Nội dung
Mô tả	Provider, model, temperature, phiên bản prompt, defense profile và <code>target_config_hash</code>
Owner	Target operator
Được phép truy cập	Runtime và harness; không cho client tùy ý đổi model trong benchmark chính thức
Threat chính	Model drift, cấu hình bị thay giữa các run, cạn quota, timeout hoặc kết quả không thể so sánh
Yêu cầu bảo vệ	Đóng băng cấu hình trong từng phép so sánh; ghi config hash; theo dõi token/latency/error
Bằng chứng vi phạm	Hai run được so sánh nhưng khác model/prompt/data mà không được ghi nhận

3. Ma trận quyền truy cập tối thiểu

Tác nhân / thành phần	Được phép	Không được phép
Khách hàng giả lập	Gửi message; nhận dữ liệu công khai và dữ liệu mock của đúng chủ thể	Đọc prompt, canary, secret, log, session khác hoặc đổi defense profile
Target agent	Đọc prompt; truy xuất context cần thiết; đề nghị gọi tool trong phạm vi	Truy cập filesystem/network tùy ý hoặc tự cấp thêm quyền
RAG service	Ingest nguồn được duyệt; retrieve chunk liên quan	Thực thi câu lệnh nằm trong tài liệu
Tool layer	Thực hiện tool allowlisted với tham số đã validate	Gọi hệ thống thật hoặc hành động ngoài sandbox
Harness/red team	Gửi attack theo RoE; thu evidence đã redact	Tấn công ngoài allowlist, vượt budget hoặc dùng dữ liệu thật
Operator/mentor	Chọn profile, bật kill switch, duyệt RoE và xem evidence	Đưa secret/artifact ra ngoài môi trường được cấp
LLM provider	Nhận prompt tối thiểu cần thiết để sinh response	Nhận API key trong prompt hoặc dữ liệu thật của người dùng